

SPECIFIKIMI I KËRKESAVE TË SOFTWARE-IT

Online Banking System

Verzioni 1.0

Field	Details
Titulli	Inxhinieri Softuerike - Online Banking System
Verzioni	1.0
Statusi	Draft
Data	25-04-2026
Subject	Inxhinieri Softuerike — Projekti
IEEE Standard	IEEE 830-1998

1. Hyrje

1.1 Qëllimi

Ky “*Software Requirements Specification*” (SRS) përshkruan kërkesat funksionale dhe jo-funksionale për “*Online Banking System*” (OBS). Synon të udhëheqë fazat e dizajnit, krijimit, zbatimit dhe testimit të projektit. Dokumenti ndjek standardin IEEE 830-1998 për specifikimet e kërkesave të softuerit.

Ky dokument është menduar për përdorim nga ekipi i zhvillimit, arkitektët e sistemit, testuesit dhe vlerësuesit akademikë të projektit të kursit të Inxhinierisë Softuerike.

1.2 Fushëveprimi

“Online Banking System” është një platformë e bazuar në “*web*” që u mundëson përdoruesve të regjistruar të menaxhojnë llogaritë e tyre bankare në mënyrë të sigurt përmes “web-it”. Sistemi do të ofrojë shërbimet e mëposhtme:

- Regjistrimi dhe verifikimi i llogarisë së përdoruesit
- Menaxhimi i llogarisë (shikimi i balancave, detajet e llogarisë, etj)
- Transaksione financiare: depozita, tërheqje dhe transferime fondesh
- Historiku i transaksioneve dhe gjenerimi i deklaratave
- Kontrolllet administrative nga stafi i bankës

Sistemi është menduar për përdorim nga klientë individualë dhe administratorë bankarë. Në këtë version, sistemi nuk do të trajtojë përpunimin fizik të parave të gatshme, menaxhimin e kredive ose integrimin e portaleve të pagesave të palëve të treta.

1.3 Përkufizime, Akronime dhe Shkurtime

Termi/Akronimi	Definicioni
OBS	Online Banking System
SRS	Software Requirements Specification
Përdorues / Klient	Një individ i regjistruar që hyn në sistem për të menaxhuar llogarinë e tij bankare
Admin	Një punonjës banke me privilegje të larta për të menaxhuar përdoruesit dhe llogaritë
JWT	“ <i>JSON Web Token</i> ” — një mjet kompakt dhe i sigurt për URL-të për përfaqësimin e pretendimeve për vërtetim
TLS	Transport Layer Security — protokoll kriptografik për sigurimin e të dhënave gjatë transaksioneve
IBAN	International Bank Account Number — format i standardizuar për identifikimin e llogarive bankare
FR	“ <i>Functional Requirement</i> ”

Termi/Akronimi	Definicioni
NFR	<i>"Non-Functional Requirement"</i>
UI	<i>"User Interface"</i>
API	<i>"Application Programming Interface"</i>
DB	Databaza

1.4 Referencat

- IEEE Std 830-1998 — IEEE Praktika e Rekomanduar për Specifikimet e Kërkesave të Softuerit
- OWASP Top 10 — Rreziqet e Sigurisë së Aplikacioneve Web (owasp.org)
- PCI DSS v4.0 — Standardi i Sigurisë së të Dhënave të Industrisë së Kartave të Pagesave
- GDPR — Rregullorja e Përgjithshme për Mbrojtjen e të Dhënave (e zbatueshme për trajtimin e të dhënave të përdoruesve)

1.5 Vështrim i Përgjithshëm

Pjesa tjetër e këtij dokumenti është e organizuar si më poshtë:

- Seksioni 2 — Përshkrim i Përgjithshëm: ofron informacion mbi produktin, përdoruesit e tij dhe kufizimet e përgjithshme.
- Seksioni 3 — Kërkesat Funksionale: numëron të gjitha veçoritë që sistemi duhet të mbështesë.
- Seksioni 4 — Kërkesat Jo-Funksionale: përshkruan kufizimet e performancës, sigurisë, besueshmërisë dhe përdorshmërisë.
- Seksioni 5 — Rastet e Përdorimit: përshkrime të detajuara të bazuara në skenarë të ndërveprimeve të sistemit.
- Seksioni 6 — Supozimet dhe Kufizimet: dokumenton kufizimet dhe varësitë e njohura.

2. Përshkrimi i Përgjithshëm

2.1 Perspektiva e Produktit

OBS është një aplikacion web i pavarur. Funksionon në mënyrë të pavarur, por lidhet me një backend të bazës së të dhënave relacionale dhe komunikon me klientët përmes një “RESTful API” mbi HTTP. Sistemi ka për qëllim të zëvendësojë ose plotësojë shërbimet bankare me bazë degësh për transaksionet rutinë.

Sistemi përbëhet nga tre komponentë kryesorë:

- Frontend: Një ndërfaqe “web” që i përshtatet përdoruesit dhe që mund të aksesohet nëpërmjet shfletuesve modernë (Chrome, Firefox, Safari, Edge).
- Backend: Një shërbim “RESTful” që përpunon të gjithë logjikën e biznesit dhe zbaton rregullat e sigurisë.
- DB: Një bazë të dhënash relacionale (MySQL) që ruan të gjitha të dhënat e përhershme.

2.2 Funksionet e produktit

Në një nivel të lartë, sistemi do të mundësojë funksionet kryesore të mëposhtme:

1. Regjistrimi dhe vërtetimi i përdoruesit (me 2FA opsional)
2. Krijimi dhe menaxhimi i llogarisë bankare
3. Transaksione financiare: depozita, tërheqje dhe transferta
4. Historiku i transaksioneve dhe deklaratat e llogarisë
5. Menaxhimi i profilit të përdoruesit (përditësimi i informacionit të kontaktit, ndryshimi i fjalëkalimit)
6. Paneli i Admin-it: menaxhoni përdoruesit, ngrin/çbllokun llogaritë, shikoni regjistrat e auditimit

2.3 Klasat dhe Karakteristikat

Klasa	Përshkrimi	Aftësi teknike
Klienti/User-i	Mbajtës të llogarive bankare individuale që përdorin sistemin për të kontrolluar bilancet, për të transferuar para dhe për të shqyrtuar historikun. Pritet të jenë publik i gjerë jo-teknik.	Të Ulëta
Administratori Bankar	Stafi i bankës përgjegjës për menaxhimin e llogarive të klientëve, shqyrtimin e transaksioneve të shënuara dhe kryerjen e operacioneve të ciklit jetësor të llogarisë.	Mesatare

2.4 Mjedisi Operativ

- Serveri: Linux (Ubuntu 22.04), Node.js/Laravel backend
- Databaza: MySQL 8+
- Klienti: Çdo shfletues modern interneti me JavaScript të aktivizuar; rezolucioni i ekranit minimal 1024x768
- Network: HTTP
- Shenjat e vërtetimit skadojnë pas 30 minutash mosaktiviteti

2.5 Kufizimet e Projektimit dhe Implementimit

- Të gjitha fjalëkalimet duhet të hashohen duke përdorur “bcrypt” me një faktor pune minimal prej 12.
- Sistemi duhet të jetë në përputhje me parimet e mbrojtjes së të dhënave të GDPR-së (minimizimi i të dhënave, e drejta e fshirjes).
- Projekti është një prototip; nuk do të integrohet me rrjete të vërteta bankare (SWIFT, ACH).
- Frontend-i duhet të jetë i përdorshëm pa “plugin”-e ose zgjerime përtej një shfletuesi standard të internetit.

2.6 Supozimet

- Përdoruesit supozohet se kanë adresa të vlefshme “email”-i për regjistrimin e llogarisë dhe njoftimet.
- Për thjeshtësi në këtë version, sistemi supozon një monedhë të vetme (EUR).
- Dërgimi i email-eve do të trajtohet nga një shërbim SMTP i palës së tretë.
- Ekipi i zhvillimit ka qasje në një server ose mjedis localhost për vendosje.
- Një grup të dhënash testimi i llogarive dhe transaksioneve të simuluar do të përdoret për zhvillim dhe testim.

3. Kërkesat Funksionale

3.1 Autentikimi i Përdoruesit dhe Menaxhimi i Llogarisë

FR-01: Regjistrimi I Përdoruesve

Sistemi duhet t'u lejojë përdoruesve të rinj të regjistrohen duke dhënë: emrin e plotë, adresën e email-it, datën e lindjes, numrin e identifikimit kombëtar dhe një fjalëkalim të zgjedhur. Sistemi duhet të vërtetojë që adresa e email-it është unike dhe jo e regjistruar tashmë. Pas regjistrimit të suksesshëm, sistemi duhet të dërgojë një email verifikimi në adresën e dhënë.

FR-02: Verifikimi Përmes “Email”-it

Sistemi do t'u kërkojë përdoruesve të rinj të verifikojnë adresën e tyre të email-it përpara se të kenë akses në ndonjë funksion bankar. Një llogari e paverifikuar do të ketë akses vetëm për lexim të kufizuar në faqen e konfirmimit të regjistrimit.

FR-03: User Login

Sistemi duhet t'u lejojë përdoruesve të regjistruar dhe të verifikuar të identifikohen duke përdorur adresën e tyre të email-it dhe fjalëkalimin. Pas vërtetimit të suksesshëm, sistemi duhet të lëshojë një token akses “JWT” (skadimi 30-minutësh) dhe një token rifreskimi (skadimi 7-ditor). Përpjekjet e dështuara të hyrjes do të regjistrohen dhe llogaritë do të bllokohen përkohësisht pas 5 përpjekjeve të dështuara radhazi brenda 15 minutave.

FR-04: “Two-Factor Authentication” (2FA) (Ndoshta)

Sistemi duhet të mbështesë autentifikimin opsional me dy faktorë të bazuar në TOTP (i pajtueshëm me Google Authenticator ose Authy). Kur aktivizohet, një kod i vlefshëm 6-shifror i bazuar në kohë duhet të dorëzohet së bashku me fjalëkalimin gjatë hyrjes.

FR-05: Ndryshimi i Fjalëkalimit

Sistemi duhet të ofrojë një rrjedhë 'Harrova Fjalëkalimin': përdoruesi fut emailin e regjistruar, merr një lidhje rivendosjeje me kohë të kufizuar (e vlefshme për 1 orë) dhe mund të vendosë një fjalëkalim të ri. Lidhjet e rivendosjes duhet të jenë njëpërdorimëshe dhe të pavlefshme pas përdorimit ose skadimit.

FR-06: “Logout”

Sistemi duhet t'u lejojë përdoruesve të dalin nga llogaria, gjë që duhet të zhvlerësojë menjëherë tokenin aktiv JWT në anën e serverit dhe të fshijë të gjitha të dhënat e sesionit nga klienti.

3.2 Operacionet e Llogarisë Bankare

FR-07: Krijimi i Llogarisë Bankare

Sistemi duhet t'u lejojë përdoruesve të autentifikuar të hapin një llogari të re bankare. Çdo llogarie duhet t'i caktohet një numër unik llogarie (formati IBAN) dhe duhet të ketë një lloj llogarie (Rrjedhëse ose Kursimi). Përdoruesit mund të mbajnë një maksimum prej 3 llogarish njëkohësisht.

FR-08: Panelin e Llogarisë

Sistemi duhet t'u shfaqë përdoruesve të autentifikuar një panel kontrolli që tregon: të gjitha llogaritë në pronësi me bilancet e tyre aktuale, numrat e llogarive (pjesërisht të maskuara), llojet e llogarive dhe datën e transaksionit të fundit.

FR-09: Detajet e Llogarië

Sistemi duhet të ofrojë një pamje të detajuar për çdo llogari, duke treguar numrin e plotë të llogarisë, IBAN-in, llojin e llogarisë, bilancin aktual, datën e hapjes dhe statusin e llogarisë (aktive / e ngrirë).

3.3 Transaksionet

FR-10: Deponimi i Fondeve

Sistemi duhet t'u lejojë përdoruesve të depozitojnë një shumë të caktuar në njërën nga llogaritë e tyre. Shuma duhet të jetë një numër pozitiv më i madh se zero. Depozita duhet të pasqyrohet menjëherë në bilancin e llogarisë dhe të regjistrohet si një hyrje transaksioni.

FR-11: Nxjerrja e Fondeve

Sistemi duhet t'u lejojë përdoruesve të tërheqin fonde nga llogaritë e tyre. Tërheqja do të refuzohet nëse: shuma e kërkuar tejkalon bilancin e disponueshëm, shuma është jopozitive ose llogaria është e bllokuar. Transaksioni duhet të regjistrohet me një vulë kohore.

FR-12: Transferimi i Fondeve

Sistemi duhet t'u lejojë përdoruesve të transferojnë fonde midis dy llogarive. Transfertat mund të jenë të brendshme (midis llogarive të vetë përdoruesit) ose të jashtme (në llogarinë e një përdoruesi tjetër të regjistruar të identifikuar nga numri i llogarisë). Sistemi duhet të vërtetojë që: llogaria burimore ka fonde të mjaftueshme, të dyja llogaritë ekzistojnë dhe janë aktive, dhe shuma e transferimit është pozitive. I gjithë transferimi duhet të ekzekutohet si një transaksion i bazës së të dhënave atomike - ose debiti dhe krediti kanë sukses, ose asnjëra nuk ka sukses.

FR-13: Transfer Confirmation

Before executing a fund transfer, the system shall display a confirmation screen showing the source account, destination account holder name, destination account number (partially masked), and amount. The user must explicitly confirm before the transfer is processed.

FR-14: Historia e Transaksioneve

Sistemi duhet të ofrojë një historik transaksionesh të faqosur për secilën llogari. Çdo hyrje duhet të tregojë: ID-në e transaksionit, llojin (kredit/debit), shumën, llogarinë e palës tjetër (nëse ka), datën dhe orën, dhe një bilanc rrjedhës. Historia duhet të jetë e renditshme sipas datës dhe e filtrueshme sipas llojit të transaksionit dhe diapazonit të datave.

FR-15: Account Statement Download

Sistemi duhet t'u lejojë përdoruesve të shkarkojnë një deklaratë llogarie në format PDF për një interval datash të zgjedhur. Deklarata duhet të përfshijë detajet e llogarisë, bilancin fillestar, të gjitha transaksionet në periudhë dhe bilancin përfundimtar.

3.4 Paneli i “Admin”-it**FR-16: View All Users**

Përdoruesit administratorë do të jenë në gjendje të shohin një listë të kërkueshme dhe të faqosur të të gjithë klientëve të regjistruar, duke përfshirë emrin, email-in, datën e regjistrimit dhe numrin e llogarive të tyre.

FR-17: Shikoni Llogaritë dhe Transaksionet e Përdoruesve

Përdoruesit administratorë do të jenë në gjendje të hyjnë në të dhënat e llogarisë së çdo klienti dhe në historikun e plotë të transaksioneve për qëllime mbështetjeje dhe auditimi.

FR-18: Ngrirje / Çbllokim Llogarive

Përdoruesit administratorë do të jenë në gjendje të ngrijnë llogarinë e një klienti, duke parandaluar çdo depozitë, tërheqje ose transferim të mëtejshëm derisa llogaria të zhblokohet. Arsyeja e ngrirjes do të regjistrohet në regjistrin e auditimit.

FR-19: Auditimi i “Log”-eve

Sistemi duhet të mbajë një regjistër të pandryshueshëm auditimi të të gjitha veprimeve administrative (hyrja, ngrirja e llogarisë, fshirja e llogarisë, rivendosja e fjalëkalimit të iniciuar nga administratori). Çdo hyrje në regjistër duhet të përfshijë: ID-në e përdoruesit të administratorit, llojin e veprimit, entitetin e synuar dhe vulën kohore.

4. Kërkesat Jo-Funksionale

4.1 Kërkesat e Sigurisë

ID	Kërkesa	Prioriteti
NFR-S01	Të gjitha fjalëkalimet duhet të hashohen duke përdorur bcrypt (faktori minimal i punës 12). Fjalëkalimet me tekst të thjeshtë nuk duhet të ruhen kurrë.	Kritike
NFR-S02	I gjithë komunikimi duhet të ndodhë nëpërmjet HTTP.	Kritike
NFR-S03	Tokenët JWT duhet të nënshkruhen me HS256 ose RS256 dhe duhet të skadojnë pas 30 minutash mosaktiviteti	Kritike
NFR-S04	Sistemi duhet të zbatojë mbrojtje kundër injektimit SQL duke përdorur pyetje të parametrizuara ose ORM.	Kritike
NFR-S05	Sistemi duhet të implementojë mbrojtje CSRF për të gjitha pikat fundore të API-t që ndryshojnë gjendjen.	Lartë
NFR-S06	Të dhënat e përdoruesit duhet të validohen dhe të dezinfektohen si në anën e klientit ashtu edhe në atë të serverit për të parandaluar XSS.	Lartë
NFR-S07	Numrat e llogarive të shfaqura në ndërfaqen e përdoruesit duhet të jenë pjesërisht të maskuar (p.sh., ****1234).	Mesatare
NFR-S08	Përpjekjet e dështuara të hyrjes duhet të jenë të kufizuara në shpejtësi: llogaria bllokohet pas 5 dështimesh në 15 minuta.	Lartë
NFR-S09	Të dhënat e ndjeshme që ruhen (kartat e identitetit kombëtar, numrat e llogarive) duhet të kodohen në bazën e të dhënave.	Lartë
NFR-S10	Pikat fundore të administratorit duhet të kërkojnë autorizim me rol të lartë dhe nuk duhet të jenë të arritshme nga përdoruesit e rregullt.	Kritike

4.2 Kërkesat e Performancës

ID	Kërkesa	Metriku
NFR-P01	Koha e ngarkimit të faqes për panelin nuk duhet të kalojë 2 sekonda në rast ngarkese normale.	< 2s
NFR-P02	Koha e përgjigjes së API-t për pyetjet standarde nuk duhet të kalojë 500ms.	< 500ms
NFR-P03	Përpunimi i transferimit të fondeve duhet të përfundojë brenda 3 sekondave.	< 3s
NFR-P04	Sistemi duhet të mbështesë të paktën 100 përdorues të njëkohshëm pa degradim.	100 concurrent
NFR-P05	Pyetjet për historikun e transaksioneve deri në 12 muaj duhet të kthehen brenda 1 sekondi.	< 1s

4.3 Besueshmëria dhe Disponueshmëria

- NFR-R01: Sistemi duhet të synojë 99.5% kohëzgjatje pune gjatë orarit normal të funksionimit (8:00-22:00 sipas orës lokale).
- NFR-R02: Sistemi duhet të zbatojë integritetin e transaksioneve të bazës së të dhënave — nuk duhet të kryhen përditësime të pjesshme.
- NFR-R03: Duhet të kryhen kopje rezervë automatike ditore të bazës së të dhënave dhe të ruhen për 30 ditë.
- NFR-R04: Sistemi duhet të shfaqë mesazhe gabimi të lehta për t'u përdorur për të gjitha kushtet e pritshme të dështimit pa ekspozuar detajet e gabimeve të brendshme.

4.4 Kërkesat e Përdorshmërisë

- NFR-U01: Ndërfaqja e përdoruesit duhet të jetë plotësisht e përgjegjshme dhe e përdorshme në madhësitë e ekraneve të desktopit, tabletit dhe celularit.
- NFR-U02: Veprimet kritike (transfertat e fondeve, ndryshimet e fjalëkalimit) duhet të kërkojnë konfirmim të qartë të përdoruesit para ekzekutimit.
- NFR-U03: Të gjitha formularët duhet të ofrojnë reagime të qarta të validimit brenda linjës brenda 500ms nga hyrja e përdoruesit.
- NFR-U04: Sistemi duhet të jetë në përputhje me udhëzimet e aksesueshmërisë WCAG 2.1 Level AA.

4.5 Kërkesat e Shkallëzueshmërisë

- NFR-SC01: Backend-i duhet të jetë pa gjendje për të lejuar shkallëzimin horizontal (istanca të shumta serverash pas një balancuesi ngarkese).
- NFR-SC02: Pyetjet në bazën e të dhënave duhet të përdorin kolona të indeksuara për të gjitha operacionet e shpeshta të kërkimit (email, numër llogarie, datë transaksioni).
- NFR-SC03: Arkitektura e sistemit duhet të mbështesë ruajtjen në memorje (p.sh., Redis) për token-et e sesionit dhe pyetjet me lexim të rëndë.

5. Përshkrimet e Rasteve të Përdorimit

UC-01: Regjistrat e Përdoruesve për Sistemin

Fusha	Pershkrimi
Rasti Perdorimit ID	UC-01
Emri	Krijimi i Perdoruesve
Aktori	Perdorues i rij(unauthenticated)
Parakushtet	Përdoruesi ka një adresë të vlefshme email-i që nuk është regjistruar ende në sistem.
Rrjedha Kryesore	1. Përdoruesi shkon në faqen e regjistrimit. 2. Përdoruesi plotëson: emrin e plotë, email-in, datën e lindjes, identifikimin kombëtar dhe fjalëkalimin. 3. Sistemi vërteton të gjitha fushat (formatin, veçantinë e email-it). 4. Sistemi krijon llogarinë e përdoruesit me statusin 'e paverifikuar'. 5. Sistemi dërgon një email verifikimi me një lidhje unike konfirmimi. 6. Përdoruesi klikon lidhjen; sistemi e shënon llogarinë si 'të verifikuar'. 7. Përdoruesi ridrejtohet në faqen e hyrjes.
Rrjedha Alternative A	A1 (hapi 3): Email-i ekziston tashmë — sistemi shfaq gabimin 'Email-i është regjistruar tashmë' dhe ndalet.
Rrjedha Alternative B	B1 (hapi 3): Fjalëkalimi nuk i plotëson kërkesat (min 8 karaktere, 1 shkronjë e madhe, 1 numër, 1 karakter i veçantë) — sistemi shfaq një gabim specifik validimi.
Postkushtet	Ekziston një llogari përdoruesi e verifikuar. Përdoruesi tani mund të identifikohet.

UC-02: Identifikimi i Përdoruesit

Fusha	Pershkrimi
Rasti Perdorimit ID	UC-02
Emri	Identifikimi i Përdoruesit
Aktori	Klient i regjistruar
Parakushtet	Përdoruesi ka një llogari të verifikuar dhe i di kredencialet e tij.
Rrjedha Kryesore	1. Përdoruesi shkon në faqen e hyrjes. 2. Përdoruesi fut email-in dhe fjalëkalimin. 3. Sistemi vërteton kredencialet kundrejt fjalëkalimit të ruajtur të hashuar. 4. Nëse 2FA është aktivizuar: sistemi kërkon kodin TOTP; përdoruesi fut kodin; sistemi vërteton. 5. Sistemi lëshon një token qasje JWT dhe një token rifreskimi. 6. Përdoruesi ridrejtohet në panelin e llogarisë.
Rrjedha Alternative A	A1 (hapi 3): Kredencialet e pavlefshme — sistemi rrit numëruesin e përpjekjeve të dështuara; shfaq mesazhin gjenerik 'Email ose fjalëkalim i pavlefshëm'.

Fusha	Pershkrimi
Rrjedha Alternative B	B1: 5 përpjekje të dështuara brenda 15 minutash — llogaria është bllokuar përkohësisht; përdoruesi njoftohet me email.
Rrjedha Alternative C	C1 (hapi 4): Kod TOTP i pavlefshëm — vërtetimi dështon; përdoruesi duhet të fusë përsëri fjalëkalimin dhe TOTP-në.
Postkushtet	Përdoruesi është i autentifikuar dhe mban një token sesioni të vlefshëm.

UC-03: Fondet e Transfertave të Përdoruesve

Fusha	Pershkrimi
ID	UC-03
Emri	Transferimi Fondeve
Aktori	Përdorues i Autentikuar
Parakushtet	Përdoruesi është i kyçur. Llogaria burimore është aktive dhe ka bilanc të mjaftueshëm.
Rrjedha Kryesore	1. Përdoruesi zgjedh 'Transferimi i Fondeve' nga paneli. 2. Përdoruesi zgjedh llogarinë burimore dhe fut numrin dhe shumën e llogarisë së destinacionit. 3. Sistemi vërteton: burimi ka fonde të mjaftueshme, llogaria e destinacionit ekziston dhe është aktive, shuma është pozitive. 4. Sistemi shfaq një ekran konfirmimi me llogarinë e destinacionit të maskuar dhe emrin e mbajtësit. 5. Përdoruesi konfirmon transferimin. 6. Sistemi ekzekuton një transaksion atomik: debitim i llogarisë burimore, kreditim i llogarisë së destinacionit, krijimi i regjistrave të transaksionit për të dyja. 7. Sistemi shfaq një mesazh suksesi me një numër reference transaksioni. 8. Sistemi dërgon njoftime me email për të dyja palët.
Rrjedha Alternative A	A1 (hapi 3): Fonde të pamjaftueshme — sistemi shfaq gabimin 'Balanci i pamjaftueshëm'; transaksioni nuk është krijuar.
Rrjedha Alternative B	B1 (hapi 3): Llogaria e destinacionit nuk ekziston — sistemi shfaq gabimin 'Llogaria nuk u gjet'.
Rrjedha Alternative C	C1 (hapi 6): Gabim në bazën e të dhënave në mes të transaksionit — i gjithë transaksioni anulohet; përdoruesi sheh një gabim të përgjithshëm; nuk kryhet asnjë përditësim i pjesshëm.
Postkushtet	Të dy llogaritë pasqyrojnë balancat e përditësuara. Ekzistojnë dy të dhëna transaksionesh. Konfirmimet me email u dërguan.

UC-04: Administratori Ngrin Një Llogari Klienti

Fusha	Pershkrimi
ID	UC-04

Fusha	Pershkrimi
Emri	Ngrije llogarinë e klientit
Aktori	Administratori Bankar
Parakushtet	Administratori është autentifikuar me rol në nivel administratori. Llogaria e synuar ekziston dhe është aktualisht aktive.
Rrjedha Kryesore	1. Administratori kërkon klientin me emër ose email. 2. Administratori shikon listën e llogarive të klientit. 3. Administratori zgjedh llogarinë që do të ngrijë dhe klikon 'Ngrij llogarinë'. 4. Sistemi i kërkon administratorit të fusë një arsye për veprimin. 5. Administratori konfirmon. 6. Sistemi e vendos statusin e llogarisë në 'të ngrirë'. 7. Sistemi e regjistron veprimin në regjistrin e auditimit me ID-në e administratorit, arsyen dhe vulën kohore. 8. Sistemi i dërgon një njoftim me email mbajtësit të llogarisë.
Rrjedha Alternative A	A1 (hapi 4): Administratori anulon — nuk bëhen ndryshime.
Postconditions	Statusi i llogarisë është 'i ngrirë'. Nuk mund të kryhen transaksione në llogari. Regjistri i auditimit është përditësuar.

6. Kërkesat e Ndërfaqes së Jashtme

6.1 Ndërfaqja e Përdoruesit

- Sistemi duhet të ofrojë një ndërfaqe përdoruesi të bazuar në internet, të aksesueshme nëpërmjet shfletuesve standardë pa shtesa shtesë.
- Navigimi duhet të përfshijë: Hyrjen, Panelin e Kontrollit, Llogaritë, Transaksionet, Transferimin, Profilin dhe (për administratorët) Panelin e Administratorit.
- Të gjitha vlerat monetare duhet të shfaqen me dy shifra dhjetore dhe simbolin e monedhës.
- Datat dhe orët duhet të shfaqen në zonën kohore lokale të përdoruesit.

6.2 Ndërfaqja API

Sistemi duhet të ekspozojë një API RESTful mbi HTTPS. Grupet kryesore të “endpoint”-ave:

Metoda	“Endpoint”	Description
POST	/api/auth/register	Regjistro Përdorues
POST	/api/auth/login	Autentitiko përdoruesin, “return JWT”
POST	/api/auth/logout	Zhvlerëso tokenin e sesionit
POST	/api/auth/reset-password	Nis rrjedhën e ndryshimit të fjalëkalimit
GET	/api/accounts	Listo të gjitha llogaritë për përdoruesin e autentifikuar
POST	/api/accounts	Krijo llogari bankare të re
GET	/api/accounts/:id	Merr detajet e llogarisë bankare
GET	/api/accounts/:id/transactions	Merrni historikun e transaksioneve
POST	/api/transactions/deposit	Depono fonde në llogari
POST	/api/transactions/withdraw	Nxjerr fonde nga llogaria
POST	/api/transactions/transfer	Transferoni fonde midis llogarive
GET	/api/admin/users	Admin: shiko të gjithë përdoruesit
PATCH	/api/admin/accounts/:id/freeze	Admin: freeze an account
GET	/api/admin/audit-log	Admin: view audit log

6.3 Ndërfaqja e Bazës Së Të Dhënave

- Sistemi duhet të përdorë një bazë të dhënash relacionale të aksesueshme nëpërmjet një ORM (p.sh., Sequelize, SQLAlchemy ose Hibernate).
- Tabelat kryesore: përdoruesit, llogaritë, transaksionet, sesionet, audit_logs, njoftimet.
- Të gjitha marrëdhëniet e çelësave të huaj duhet të zbatojnë integritetin referues në nivelin e bazës së të dhënave.
- Kolonat e ndjeshme (national_id, account_number) duhet të enkriptohen në shtresën e aplikacionit para ruajtjes.

6.4 Ndërfaqja e Komunikimit

- I gjithë komunikimi klient-server duhet të përdorë HTTP.
- Emaillet transaksionale (konfirmimi i regjistrimit, rivendosja e fjalëkalimit, njoftimet e transferimit) duhet të dërgohen nëpërmjet SMTP nëpërmjet një ofruesi të palës së tretë.
- Përgjigjet e API-t duhet të përdorin formatin JSON me strukturë të standardizuar të përgjigjes së gabimit: { status, message, errors }.

7. Matrica e Gjurmueshmërisë Së Kërkesave

Tabela më poshtë përputhet me çdo funksionalitet sipas rastit/rasteve në lidhje me përdorimin dhe përfundimin e testimit që do të verifikojë atë.

ID Kërkesa	Pershkrimi	Rasti i Përdorimit	Faza e Testimit
FR-01	Regjistrimi i Përdoruesit	UC-01	Integration, Security
FR-02	Verifikimi përmes Email	UC-01	Integration
FR-03	Regjistrimi i Përdoruesit	UC-02	Integration, Security
FR-04	2FA (ndoshta)	UC-02	Integration, Security
FR-05	Ndryshimi i Fjalekalimit	UC-02	Integration, Security
FR-06	“Logout”	UC-02	Integration
FR-07	Krijimi i Llogarise	—	Unit, Integration
FR-08	Paneli i Llogarise	—	Integration
FR-09	Detajet e Llogarise	—	Integration
FR-10	Deponimi i Fondeve	—	Unit, Integration
FR-11	Marrja e Fondeve	—	Unit, Integration
FR-12	Transferimi i Fondeve	UC-03	Unit, Integration, Security
FR-13	Konfirmimi i Transaksioneve	UC-03	Integration
FR-14	Historia e Transaksioneve	—	Integration
FR-15	Shkarkimi i Deklaratës	—	Integration
FR-16	Admin: Shiko Përdoruesit	UC-04	Integration, Security
FR-17	Admin: Shiki Llogari	UC-04	Integration, Security
FR-18	Admin: Ngrij Llogari	UC-04	Integration, Security
FR-19	Auditimi “Log”-eve	UC-04	Integration

8. Shtesë

8.1 Politika e Fjalëkalimit

Të gjitha fjalëkalimet e përdoruesve duhet të plotësojnë kërkesat minimale të mëposhtme:

- Gjatësi minimale 8 karaktere
- Të paktën një shkronjë e madhe (A–Z)
- Të paktën një shkronjë e vogël (a–z)
- Të paktën një shifër (0–9)
- Të paktën një karakter i veçantë (!@#\$\$%^&*)

8.2 Politika e Ruajtjes Së Të Dhënave

- Të dhënat e llogarisë së përdoruesit: ruhen për gjithë jetëgjatësinë e llogarisë plus 7 vjet pas mbylljes (kërkesë ligjore).
- Të dhënat e transaksioneve: ruhen për një minimum prej 7 vjetësh.
- Regjistrat e auditimit: ruhen për një minimum prej 3 vjetësh.
- Tokenët e sesionit: zhvlerësohen dhe fshihen pas skadimit.
- Tokenët e verifikimit dhe rivendosjes së fjalëkalimit: fshihen 24 orë pas krijimit.

8.3 Fjalorthi i Kodeve të Gabimit

HTTP Kodi	Domethenja	Shembull
200 OK	"Request succeeded"	Successfully fetched account details
201 Created	"Resource created"	Bilanc i ri i hapur
400 Bad Request	"Invalid input"	Shuma e transferimit është negative
401 Unauthorized	"Not authenticated"	JWT tokeni mungon
403 Forbidden	"Authenticated but not authorized"	Klienti po përpiqet të hyjë në pikën fundore të administratorit
404 Not Found	"Resource does not exist"	Numri i llogarisë nuk u gjet
409 Conflict	"Duplicate resource"	Email-i ekziston
422 Unprocessable Entity	"Business rule violation"	Bilanci i pamjaftueshëm për tërheqje
429 Too Many Requests	"Rate limit exceeded"	Shum kërkesa "Log In"
500 Internal Server Error	"Unexpected server error"	Konektimi me DB deshtoj

— End of Document —